



Risk Analysis and Impact Assessment

EVALUATING POTENTIAL THREATS AND MEASURING CONSEQUENCES
FOR INFORMED DECISION-MAKING



GRC GATE TRAINING

Introduction to Risk Analysis and Impact Assessment

Risk analysis transforms raw data about threats into actionable insights

- Enables informed decisions and protection of valuable assets

It is a critical component for businesses, governments, and individuals

- Ensures ongoing health of operations and wise allocation of resources

Understanding risk analysis empowers prioritization and resource allocation

- Helps secure systems, manage projects, and safeguard resources

Defining Risk Analysis

Risk analysis is a systematic process with distinct phases

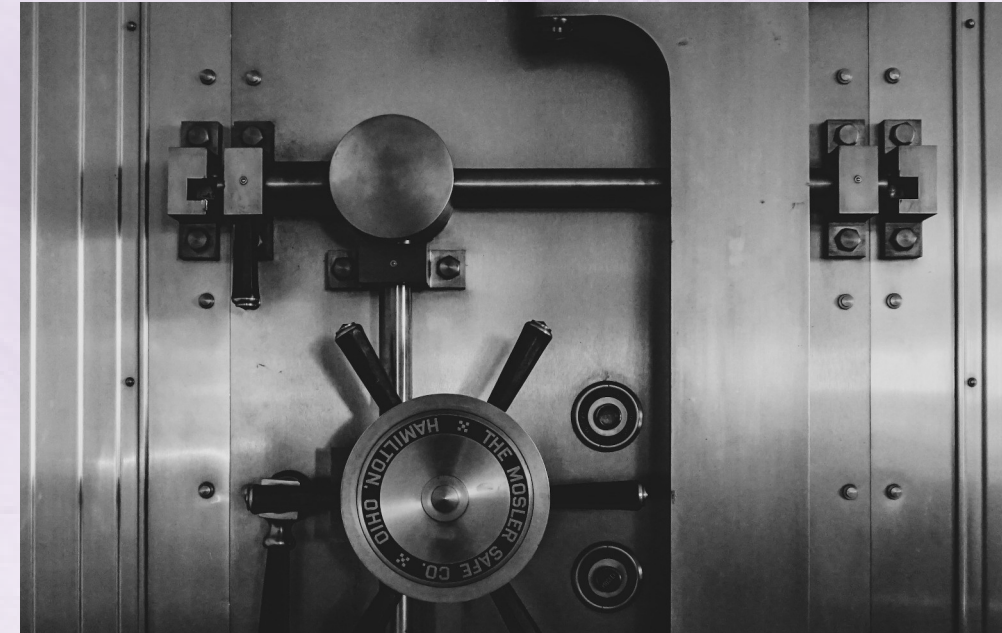
- Identification, evaluation of likelihood, and estimating potential impact

It is more than a checklist, but a disciplined approach

- Distinguishes minor issues from catastrophic threats for proper response

Main branches are qualitative and quantitative techniques

- Choice depends on context, resources, and maturity of risk management



Qualitative Risk Analysis

Qualitative risk analysis uses descriptive categories like high, medium, or low

- Assesses both likelihood and severity when time or data are limited

Example: Small business rates ransomware attack using relative likelihood and impact

- Medium likelihood due to industry trends, high impact due to customer data loss

Strength is rapid triage and stakeholder consensus, but can be subjective

- Relies on experience and perception rather than hard data

Semi-Quantitative Risk Analysis

Semi-quantitative analysis assigns numerical values to descriptive categories

- Blends simplicity of qualitative with objectivity of quantitative methods

Example: Likelihood and impact rated, multiplied for a risk score (e.g., $3 \times 4 = 12$)

- Risk scores can be plotted on a heat map for visual representation

Useful for systematic prioritization without full quantitative data

- Bridges the communication gap between technical and non-technical stakeholders





Quantitative Risk Analysis

Quantitative analysis uses numerical probabilities and estimates expected losses

- Results expressed in concrete terms, such as dollars or euros

Techniques include Monte Carlo simulations, fault tree and event tree analysis

- Used to estimate specific losses, such as annualized loss expectancy in banks

Most precise and defensible, but requires significant data and expertise

- More common in high-stakes sectors like aerospace, finance, or energy

Impact Assessment for the CIA Triad

CIA triad: confidentiality, integrity, and availability are foundational

- Used to assess risks across information security dimensions

Impact assessed for each dimension, e.g., data breach affects all three

- Confidentiality compromised by disclosure, integrity by alteration, availability by downtime

Thorough assessment considers regulatory, operational, and reputational impacts

- Ensures risk management addresses all consequences



```
video = { type: "video",  
  source: "https://www.youtube.com/watch?v=...",  
  element: { type: "video",  
    subject: { type: "video",  
      if boxer is already active,  
      "boxer").length > 1 || (false)  
    }  
  }  
}  
  
event  
nt(e);  
  
internal data  
extend(0, {  
  window: $(window),  
  body: $("body"),  
  target: $target,  
  subject: $subject,  
  active: false,  
  timer: null,  
  timer: null,  
  timer: {  
    active: false
```

Determining Likelihood

Likelihood estimates how probable a specific threat will exploit a vulnerability

- Central to risk analysis, combines various risk factors

Threat capability measures adversary skills, resources, and motivation

- Nation-state actors pose greater threats than casual hackers

Control strength refers to effectiveness of security controls in place

- High control strength reduces likelihood; weak controls increase risk

Assigning Risk Levels Using Matrices and Scores

Risk matrix (heat map) plots likelihood and impact to assign risk levels

- High-likelihood/high-impact risks need immediate attention, low ones can be monitored

Visual summaries help stakeholders grasp risk profiles quickly

- Heat maps and scoring bring clarity for decision-making

Scoring multiplies numerical values for objective prioritization

- Scores and ranks direct resources to the most pressing threats



Documenting and Communicating Results

Clear documentation ensures transparent and reproducible risk assessments

- Identified risks, ratings, rationale, and assumptions are documented

Communication tailors risk findings for different stakeholder audiences

- Executives get summaries, technical teams get detailed threats and vulnerabilities

Visual aids like heat maps and dashboards enhance understanding

- Build risk awareness and support informed decisions across the organization

Challenges in Risk Analysis

Common challenges include limited data and competing priorities

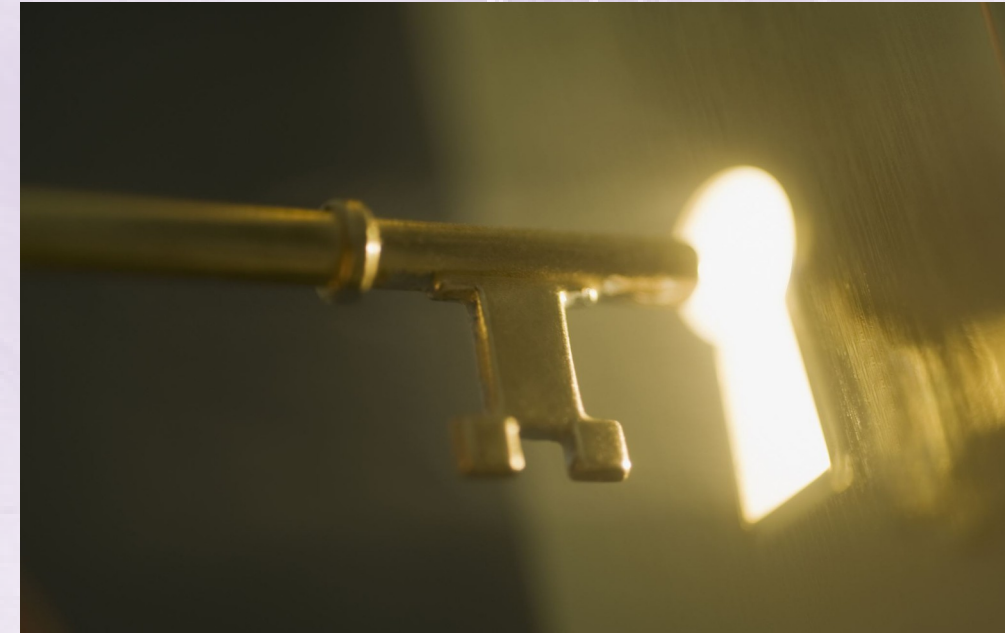
- Rigor versus efficiency can limit thorough quantitative analysis

Tiered approach: qualitative for screening, quantitative for critical risks

- Allocates effort according to risk significance and resources

Overcoming subjective bias and keeping pace with change is essential

- Workshops, diverse teams, and updating methods help maintain objectivity





Keys to Successful Risk Analysis

Invest in reliable data sources and cross-functional collaboration

- Improves data quality and risk insights across the organization

Embed risk analysis into daily decision-making processes

- Makes risk management part of organizational culture

Use automated tools, but rely on human judgment for context

- Regular review and updates keep assessments agile and relevant

Summary of Risk Analysis and Impact Assessment

Risk analysis and impact assessment are foundations of risk management

- Methods must fit organizational needs and available resources

Assessing confidentiality, integrity, and availability addresses all critical aspects

- Comprehensive risk management considers regulation, operations, and reputation

Assigning risk levels, documenting, and communicating results enable prioritization

- Builds transparency, accountability, and supports informed action and innovation

